Open in app ↗ Sign up Sign in

Medium Search

InfoSec Write-ups · Follow publication

Cybsersecurity + Ics Security + Critical Infrastructure + Ot Penetration Testing +

Mitre Attack For Ics +

OT Penetration Testing Methodology: How to Test Industrial Systems Without Breaking Them

A safety-first methodology for testing industrial systems where one wrong scan can stop a physical process

10 min read · Mar 3, 2026



urjasec Follow

Listen Share

A penetration tester runs *nmap -sV -A 10.10.20.0/24* against a network segment at a water treatment facility. Standard procedure, something they've done hundreds of times on corporate networks. Within seconds, a Siemens S7–1200 PLC enters a fault state. The control room alarm fires. An operator scrambles to perform a hard reset while the plant manager picks up the phone. For eleven minutes, automated chlorine dosing stops.

> ***This wasn't an attack. It was a security assessment.***

The pentester did nothing wrong by IT standards, aggressive service detection is textbook methodology. But in OT, textbook IT methodology can cause exactly the kind of disruption you were hired to prevent. The assessment was halted. Trust with

the operations team, the most important asset in any OT engagement took days to rebuild.

This isn't hypothetical. Research by Coffey et al. (2018) documented how standard network scanning tools crash isolated ICS components. Devices that have run flawlessly for fifteen years suddenly fault because they received packets they were never designed to handle.

If you've been following this **series**, you know the foundations: ICS architecture, industrial protocols, real-world attacks from Stuxnet to Triton, and security frameworks. Now we enter offensive security but "offensive" in OT carries a different weight. The first rule of OT penetration testing **is do no harm**.

Note: Not every OT security engagement is a penetration test the spectrum runs from passive architecture reviews to full adversary simulation. Most organizations start with observation and analysis, not exploitation. That's appropriate. You walk before you run. This article covers the full methodology so you understand the complete picture.

The Mindset Shift: IT vs OT Pentesting

If you're coming from IT pentesting, everything you know about scanning, exploitation, and pivoting still applies but filtered through a completely different lens: **in IT, you optimize for finding vulnerabilities. In OT, you optimize for finding vulnerabilities without disrupting the process.**

Dimension	IT Pentesting	OT Pentesting
Primary concern	Confidentiality (data theft)	Availability (process uptime)
Failure consequence	Data breach, financial loss	Physical damage, injury, death
Scan tolerance	Handles aggressive scans	A single SYN scan can crash a PLC
Test window	Anytime (usually)	Maintenance windows only, or lab replicas
"Success"	Compromise domain admin	Map attack paths WITHOUT disruption
Protocol knowledge	TCP/IP, HTTP, SMB, AD	Modbus, DNP3, EtherNet/IP, OPC-UA, S7comm
Exploit validation	Run the exploit	Analyze the path, demonstrate in lab, never against production

Figure 1: IT vs OT Pentesting — The 7 dimensions that change everything

Here's what training courses don't prepare you for: the first time you walk onto a plant floor for an OT assessment, you realize the supports aren't abstract. That PLC you're about to scan controls a valve feeding chemical into drinking water. The HMI screen in front of you shows a live reactor temperature. The operator next to you has kept this process running safely for twenty years and is watching your every move with justified suspicion. That weight — the reality of physical consequence — is the mindset shift. It changes how you think about every packet you send.

OT pentesters think in **physical processes**, not networks and hosts. Before you scan a single port: What does this PLC control? What happens if it stops? What's downstream? What's the blast radius, digital AND physical?

And you are never alone. OT pentesting is not a solo operation. You work alongside process engineers, operations staff, and safety personnel. Every test action is communicated in real time. In IT, you try to stay hidden. In OT, you announce every move.

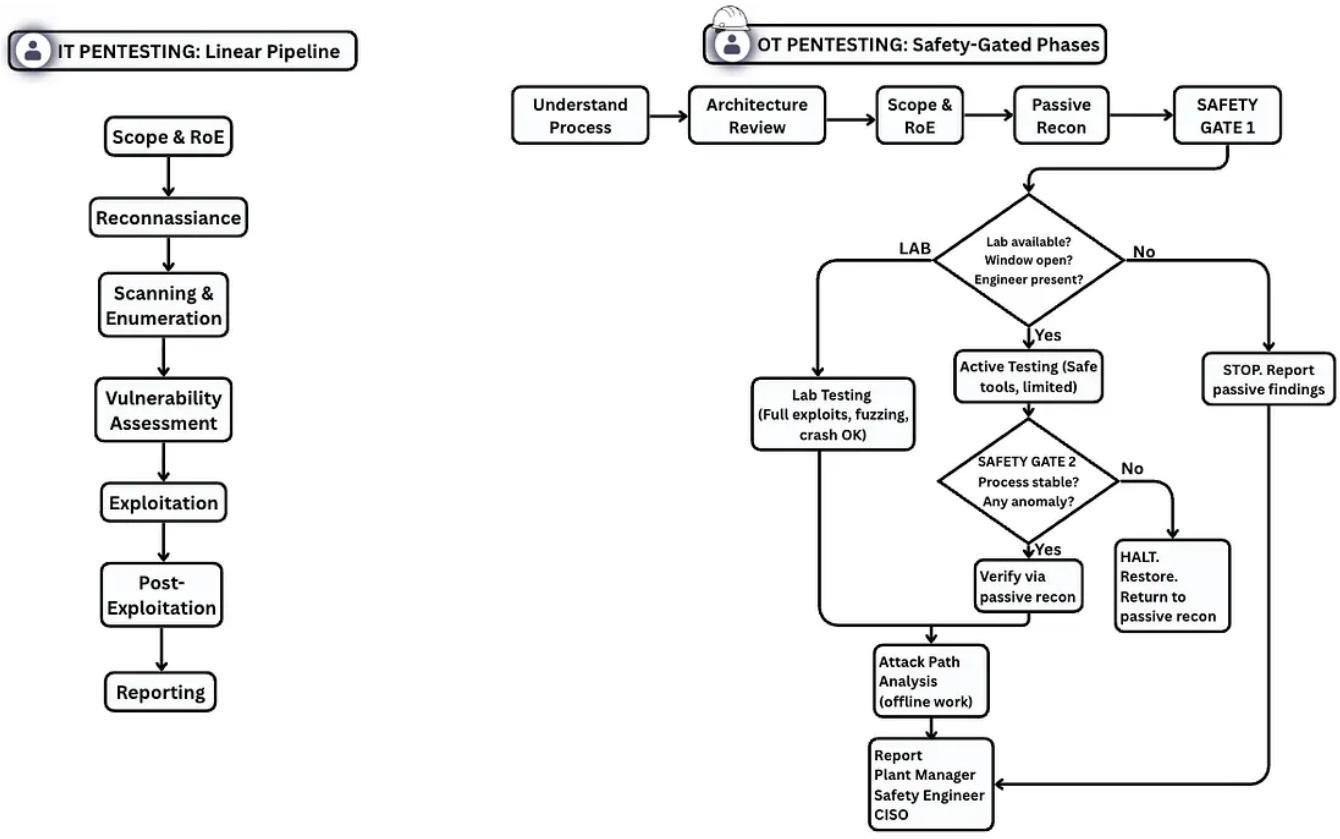


Figure 2: IT pentesting gates are administrative — once authorized, phases flow freely. OT pentesting gates are safety-critical — each transition requires confirming physical process stability. The lab path bypasses Gate 2 (no production process at risk) and feeds directly into offline analysis. A “NO” at any gate is a valid outcome, not a failure.

Before You Touch Anything: Safety, Scoping, and Rules of Engagement

Rules of Engagement

In IT, the RoE is a formality, scope, timeline, emergency contacts. In OT, the RoE is a **safety protocol** that prevents industrial incidents. Getting it wrong doesn’t mean a compliance issue. It means someone could get hurt.

Every OT pentest RoE must include:

1. Safety Boundaries
SIS, active safety controllers, and anything at Purdue Level 0–1 in production are off-limits. Documented by name, IP, and physical location.

2. Communication & Escalation
Direct phone or radio to the control room operator and on-call process engineer. Not a ticketing system. The tester must have the authority to immediately cease all testing if any anomaly is observed. When you're about to send a packet to a controller, the operator knows before you hit Enter.

3. Maintenance Window Alignment
Active testing against production happens only during scheduled maintenance when the process is safely shut down.

4. Rollback Plans
For every test action, a documented procedure to restore the original state. "If we send this Modbus write to register 40001, here's how we restore the original value and verify the process returned to normal."

5. Asset Verification
Verify the asset list against reality before touching anything. An IP that was "supposed to be a historian" might actually be an active HMI controlling a live process.

> ***The Golden Rule:*** *If you don't understand what a device controls, you don't touch it. Period.*

The Pre-Assessment Architecture Review

Before defining scope, you need to understand the environment. This is the most critical phase and it happens before a single packet leaves your laptop.

1. Collect documentation
Network diagrams, P&IDs (Piping and Instrumentation Diagrams), data flow diagrams, asset inventories. Many facilities have outdated documentation that itself is a finding.
2. Map to the Purdue Model
Map every known asset to its Purdue level (Part 3). This determines your testing approach for each one.
3. Identify crown jewel assets

Which processes, if compromised, cause the greatest harm? A chlorine dosing system. A turbine controller. A reactor shutdown system. These drive your priorities.

4. Understand process dependencies

If PLC-A fails, does the entire line stop or just one station? Does the SIS trigger? Is there a manual backup? Dependencies determine blast radius.

5. Identify IT-OT convergence points

Where does corporate touch industrial? The DMZ, historian connections, remote access paths, vendor VPNs, these are your primary testing targets.

Scoping by Purdue Level

Purdue Level	Testing Approach	Risk
Level 4-5 (Enterprise)	Standard IT pentesting applies	Low
Level 3.5 (Industrial DMZ)	Careful testing — the bridge between worlds	Medium
Level 3 (Site Operations)	Active testing during maintenance windows only	Medium-High
Level 2 (Supervisory)	Active testing with extreme caution, operations staff present	High
Level 1 (Controller)	Passive only in production; active only in lab or full shutdown	Critical
Level 0 (Physical Process)	Never directly tested; impact assessed through Level 1 analysis	Off-limits

Figure 3: Testing approach by Purdue Level — risk escalates as you go deeper

The key deliverable from scoping is a **Testing Boundary Document** mapping every in-scope asset to: its Purdue level, testing authorization (active/passive/off-limits), available maintenance window, rollback procedure, and responsible engineer contact. No document, no testing.

Passive Reconnaissance: Where 80% of Your Findings Live

In IT pentesting, passive recon is the warm-up before the real action. In OT, **passive recon IS the action** for most of the engagement. You can learn an extraordinary amount without sending a single probe packet.

Network Traffic Capture

The foundation is traffic capture using SPAN (mirror) ports on network switches or dedicated network TAPs. A TAP is preferred as it copies traffic without introducing any load.

Get urjasec's stories in your inbox

Join Medium for free to get updates from this writer.

Subscribe

Remember me for faster sign in

What you're looking for: protocol identification (Modbus on 502? S7comm on 102?), device enumeration via MAC OUI lookup, communication patterns and polling cycles, cleartext credentials (Modbus has zero authentication), anomalous connections to unexpected IPs, and broadcast traffic that reveals topology.

Passive Discovery Tools

Tool	Purpose
Wireshark (with OT dissectors)	Protocol analysis such as decodes Modbus, DNP3, S7comm, EtherNet/IP, OPC-UA
GrassMarlin (NSA/CISA)	Passively maps ICS network topology from traffic captures
NetworkMiner	Passive host and OS identification from PCAPs
Nozomi / Claroty / Dragos (commercial)	Deep packet inspection across 100+ OT protocols with risk scoring

Figure 4: OT passive discovery toolkit

What 48 Hours of Listening Reveals

Let's take an example of a passive analysis at a power utility over 48 hours revealed:

- 47 devices identified across Purdue Levels 1–3
- Modbus TCP communication between the SCADA master and 12 RTUs was found to be completely unencrypted, with function codes and register values transmitted in plaintext

- An engineering workstation was observed making periodic S7comm connections to a PLC without any authentication
- An HTTP connection from a Level 2 HMI to an external IP was discovered — a forgotten vendor remote access session that had been active for 9 months
- DNP3 communication between two substations was running with Secure Authentication disabled
- Three devices were found using default SNMP community strings ("public")
- A flat network was identified between Level 2 and Level 3, with no segmentation between supervisory HMIs and site operations

Every one of these is a significant finding. None required sending a single packet.

> ***Passive recon alone can reveal 80% of the vulnerabilities in an OT environment.*** *Unencrypted protocols, flat networks, unauthorized connections, default credentials, they're all visible just by listening.*

Active Testing: What's Safe, What's Not

This is where IT pentesters become dangerous. The tools you've used thousands of times can cause real damage to industrial systems.

The Danger Zone: IT Tools That Break OT

IT Tool / Technique	What Happens in OT
nmap -sV -A (aggressive scan)	OS detection sends malformed packets. PLC enters fault state, process stops.
nmap -O (OS detection)	SYN without teardown, FIN+PSH+URG probes crash primitive TCP/IP stacks
Nessus / Qualys (full scan)	Thousands of checks — can factory-reset devices, corrupt firmware, crash PLCs
Metasploit (generic exploits)	Untested against OT firmware. Unpredictable: bricked devices, corrupted logic, triggered safety systems.
Fuzzing tools	Designed to crash things. Never acceptable against production OT.
ARP spoofing / MitM	Breaks real-time control loops. Causes process upset or safety shutdown.

Figure 5: The danger zone — IT tools that break industrial systems

The core problem: Industrial controllers run minimal TCP/IP stacks designed for a specific set of expected communications. They have no concept of "unexpected but benign." Anything outside their expected pattern is either ignored (best case) or causes a fault (worst case).

OT-Safe Approaches (When Authorized)

When active testing must be conducted during scheduled maintenance windows on approved targets, with an engineer present.

- **`nmap -sT -T2 --max-retries 1`** — Full TCP handshake with clean teardown. Target specific known ports only.
- **Redpoint NSE scripts** (`modicon-info`, `enip-enumerate`, `s7-info`) — Legitimate protocol queries, identical to a real SCADA client.
- **Manual protocol interaction** — Hand-crafted Modbus TCP read requests (function codes `0x03` / `0x04`). Read-only. Never write to production.
- **Credential testing on Level 3+** — HMI login pages, historian databases, remote access portals.
- **Web application testing** — OWASP methodology against HMI web portals. Many run outdated web servers.
- **Offline configuration review** — Exported PLC programs, firewall rules, switch configs. Zero risk, high value.

The field rule: Know EXACTLY what packets each tool option sends. If you can't explain what `-sV` does at the packet level, you aren't ready to use it against a controller. Always minimize packets — a targeted scan of 10 known ports is infinitely safer than 65,535.

OT Protocol Port Reference

Target these ports when scanning is authorized and never scan full ranges:

Port	Protocol	Notes
502/TCP	Modbus TCP	Zero authentication
102/TCP	S7comm	Siemens S7 PLCs
44818/TCP	EtherNet/IP (CIP)	Rockwell/Allen-Bradley
20000/TCP	DNP3	Power grid SCADA
4840/TCP	OPC-UA	Modern interoperability
47808/UDP	BACnet	Building automation
1911/TCP	Niagara Fox	Tridium building automation
9600/TCP	OMRON FINS	OMRON PLCs

Figure 6: OT protocol port reference

Lab vs. Production

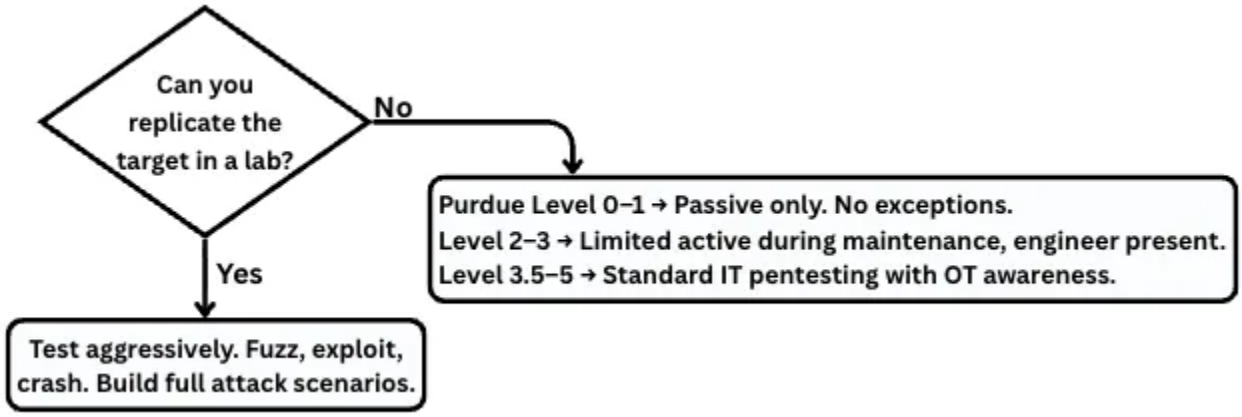


Figure 7: Lab vs production — the first question at every safety gate

Mapping the OT Attack Surface

The OT attack surface is wider than most IT pentesters expect. Structure findings using MITRE ATT&CK for ICS:

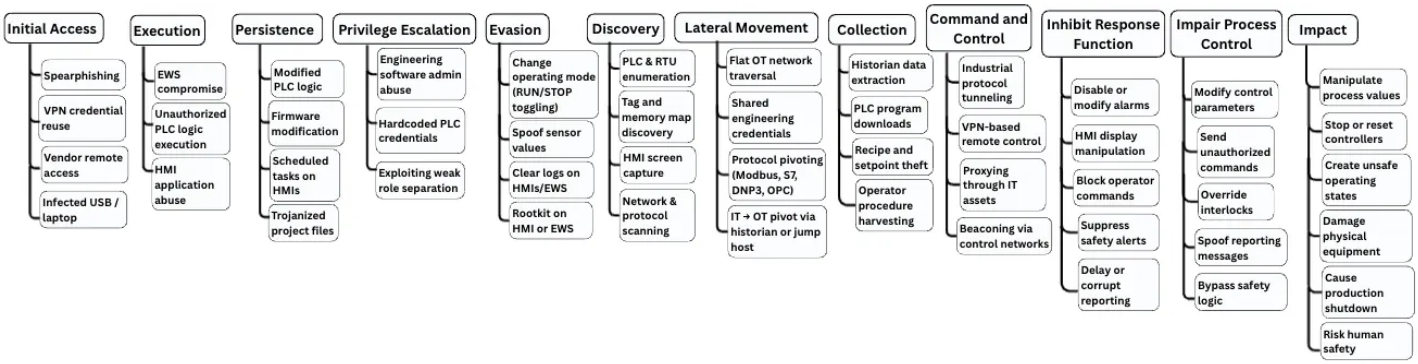


Figure 8: OT attack surface mapped to MITRE ATT&CK for ICS

The most commonly exploited entry points: HMI workstations running unpatched Windows (often still XP Embedded), engineering workstations with direct PLC access and stored credentials, historians exposed to IT networks with default creds and SQLi, weak VPN credentials (Colonial Pipeline started with one compromised account), and forgotten always-on vendor connections with shared credentials across sites (Stuxnet leveraged this).

Your existing IT skills apply directly at Level 3 and above — Active Directory attacks, web testing on HMI portals, network pivoting, credential spraying. Default passwords are endemic (the Oldsmar incident involved shared TeamViewer credentials). But below Level 3, protocol knowledge and process understanding become non-negotiable.

Reporting for OT Stakeholders

Your report speaks to three audiences who speak three different languages. Miss any one of them and your findings die in a drawer.

The **plant manager** cares about production and safety — “this vulnerability could cause a 72-hour shutdown costing $2.4M” **The safety engineer** cares about SIS integrity — “this attack path bypasses the safety system for reactor R-201, creating an uncontrolled pressure scenario.” **The CISO** cares about risk scores and

compliance — “critical finding mapped to IEC 62443 SR 5.1, NIST CSF PR.AC-5.”

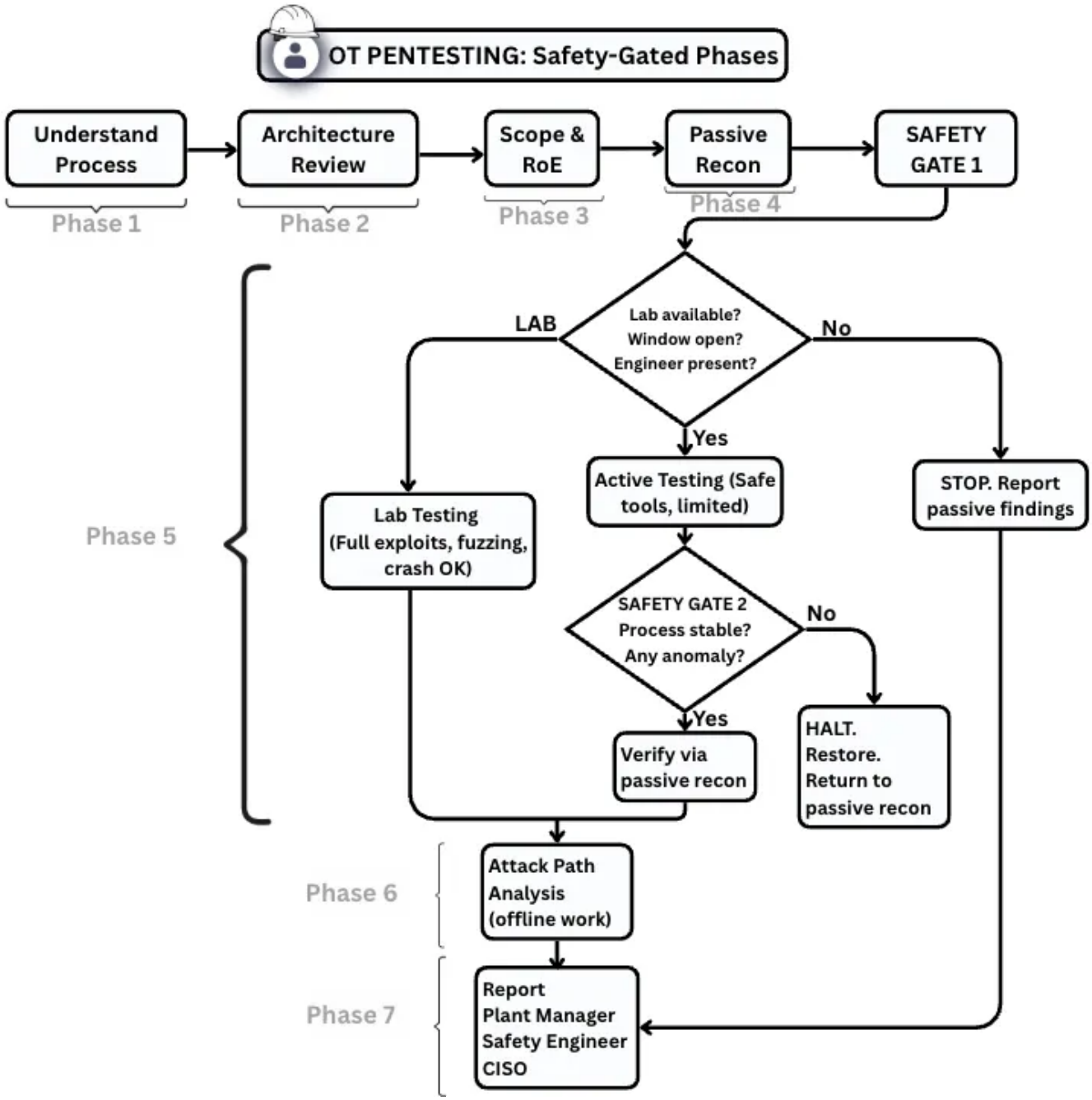
The critical difference from IT reports: don’t just list findings **build attack path narratives.**

> *Not “SQL injection on Historian-01” but “Attacker compromises VPN with reused credentials → pivots to historian via SQL injection → moves to engineering workstation via shared admin password → downloads PLC program → modifies control logic for pump P-101 → causes over-pressurization. The SIS would catch this specific scenario but we identified three additional paths that bypass the SIS entirely, creating unmitigated safety risk.”*

Prioritize by safety impact first, production impact second, ease of exploitation third. Map findings to IEC 62443 and NIST CSF requirements — that’s the language that gets budget approved.

The Complete OT Pentesting Methodology

Seven phases, with safety gates at every step:



Key Takeaway

Here's what separates a competent OT pentester from an exceptional one: the competent pentester finds vulnerabilities. The exceptional one understands what they mean for the physical world, what happens to the water, the power, the chemicals, the people downstream.

That understanding doesn't come from tools or certifications. It comes from walking plant floors, listening to operators, studying process diagrams, and never forgetting that the systems you're testing keep people alive. The tools transfer, the techniques adapt, but the respect for physical consequence, that you have to earn.

Our next series is **Building Your OT Security Lab**. You can't practice OT pentesting safely without a lab to break things in. We'll set up OpenPLC, configure SCADA simulators like GRFICSv2, and build a safe environment to practice everything from Modbus exploitation to PLC logic attacks which is dropping next week. See you there.

If you missed the earlier posts:
- Part 1: The Hidden World of Critical Infrastructure
- Part 2: Inside ICS Components
- Part 3: The Purdue Model: Understanding OT Network Architecture
- Part 4: Industrial Protocols: Modbus and DNP3
- Part 5: Modern Industrial Protocols: PROFINET, EtherNet/IP, OPC-UA, and IEC 61850
- Part 6: Wireless in OT: WirelessHART and ISA 100.11a
- Part 7: Common OT Attacks: From Stuxnet to FrostyGoop
- Part 8: Living Off the Land in OT Environments
- Part 9: IEC 62443: The Security Standard Built for Industrial Control Systems
- Part 10: NIST Cybersecurity Framework for OT
- Part 11: NERC CIP: The Mandatory Standard Protecting North America's Power Grid
- Part 12: Framework Comparison: IEC 62443 vs NIST CSF vs NERC CIP

Until then, let's explore OT/ICS security and work toward making critical infrastructure more secure.

Stay curious, stay secure.

Cybsersecurity + Ics Security + Critical Infrastructure +

Ot Penetration Testing + Mitre Attack For Ics +



Follow

Written by urjasec

54 followers · 9 following

Electrical Engineer | Research on OT/ICS security | OSCP, CREST, CRTO, CRTE



Follow

Published in InfoSec Write-ups

89K followers · Last published Oct 29, 2026

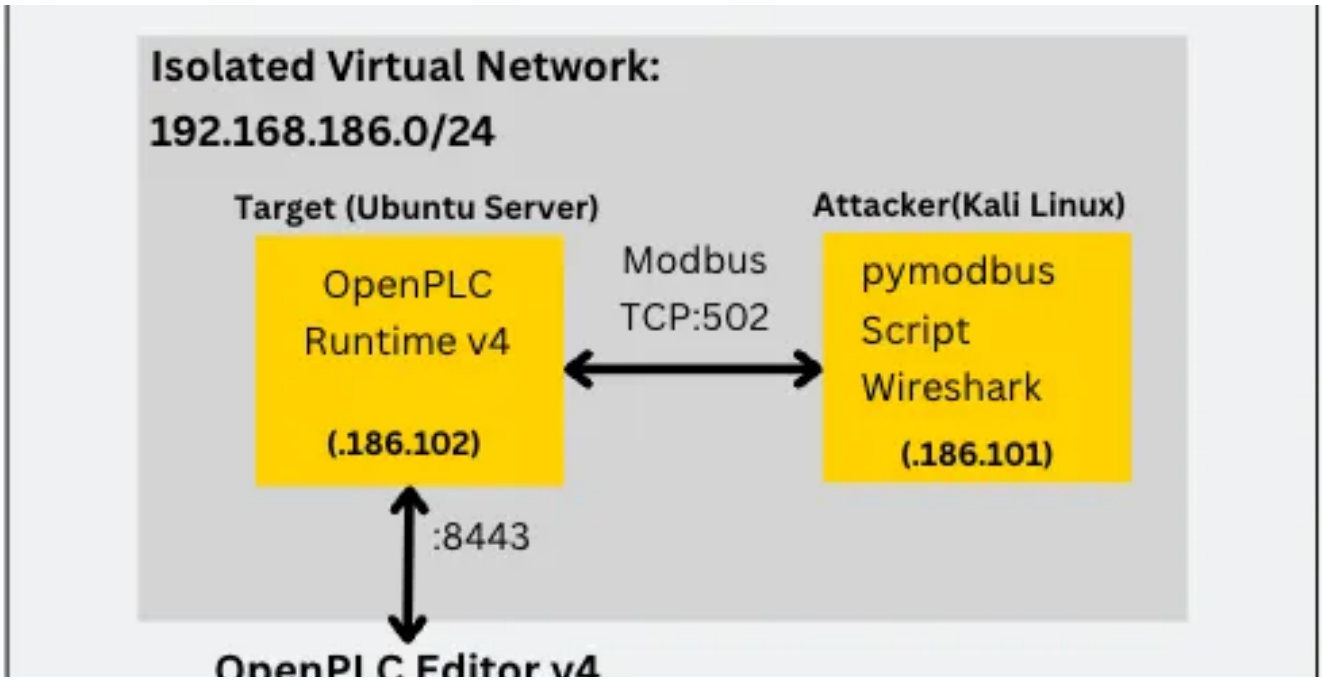
A collection of write-ups from the best hackers in the world on topics ranging from bug bounties and CTFs to vulnhub machines, hardware challenges and real life encounters. Subscribe to our weekly newsletter for the coolest infosec updates: https://weekly.infosecwriteups.com/

No responses yet

Write a response

What are your thoughts?

More from urjasec and InfoSec Write-ups



urjasec · Mar 15

Building Your OT Security Lab: Hands-On Manual Setup

Build a PLC, write Modbus scripts, and see why industrial protocols are still dangerously insecure



In InfoSec Write-ups by ***Lostsec*** · Aug 27

The Best Claude Code Setup for Bug Bounty Hunting

Turn Claude Code into a powerful bug bounty hunting assistant with MCP, custom skills, agents, tools and automated security workflows.

843 13 7



In InfoSec Write-ups by RivuDon · Oct 29

My Second Year in Bug Bounty $$$$

Learn from my experience and use it in yours.

83 3



In MeetCyber by urjasec · Nov 24, 2025

The Hidden World of Critical Infrastructure: Why OT/ICS Security Matters More Than You Think

Understanding Critical Infrastructure: The Invisible Backbone of Modern Life

5

See all from urjasec

See all from InfoSec Write-ups

Recommended from Medium



Taimur Ijlal · Aug 1

Agentic AI Red Teaming: How to Start From Scratch in 2026 (100% Free Resources)

The Hugging Face Attack Has Made Agentic AI Red Teaming a red hot career ..

391 17 2

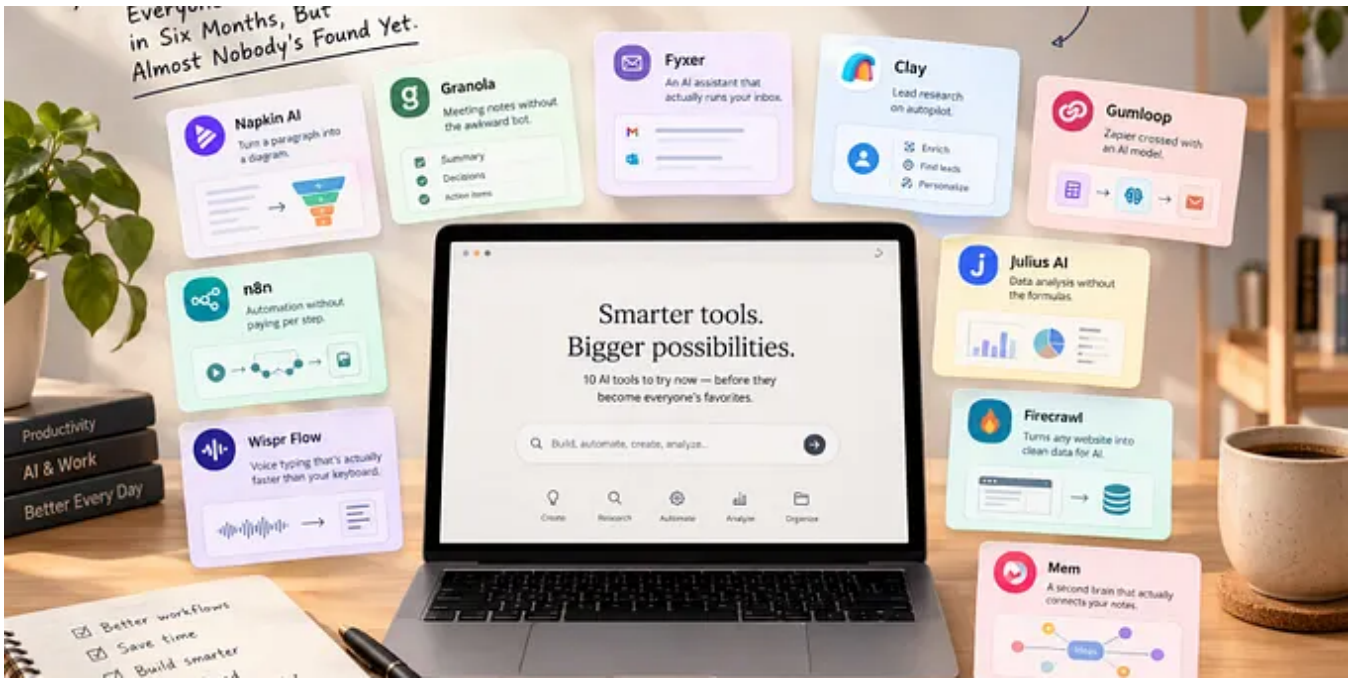


In System Weakness by Ismail Tasdelen · Jul 21

100 Cybersecurity Resources That Actually Matter

The internet is drowning in “top 10 cybersecurity resources” lists that cycle through the same five websites, forever. You’ve seen them...

232 2 5



In Artificial Intelligence in Plain English by Vruddhi Shah · Sep 30

10 AI Tools Everyone Will Be Using in Six Months, But Almost Nobody's Found Yet

You're going to see these in someone's toolkit next year and wonder why you didn't hear about them first. Here's your head start.

6.9K 183 67

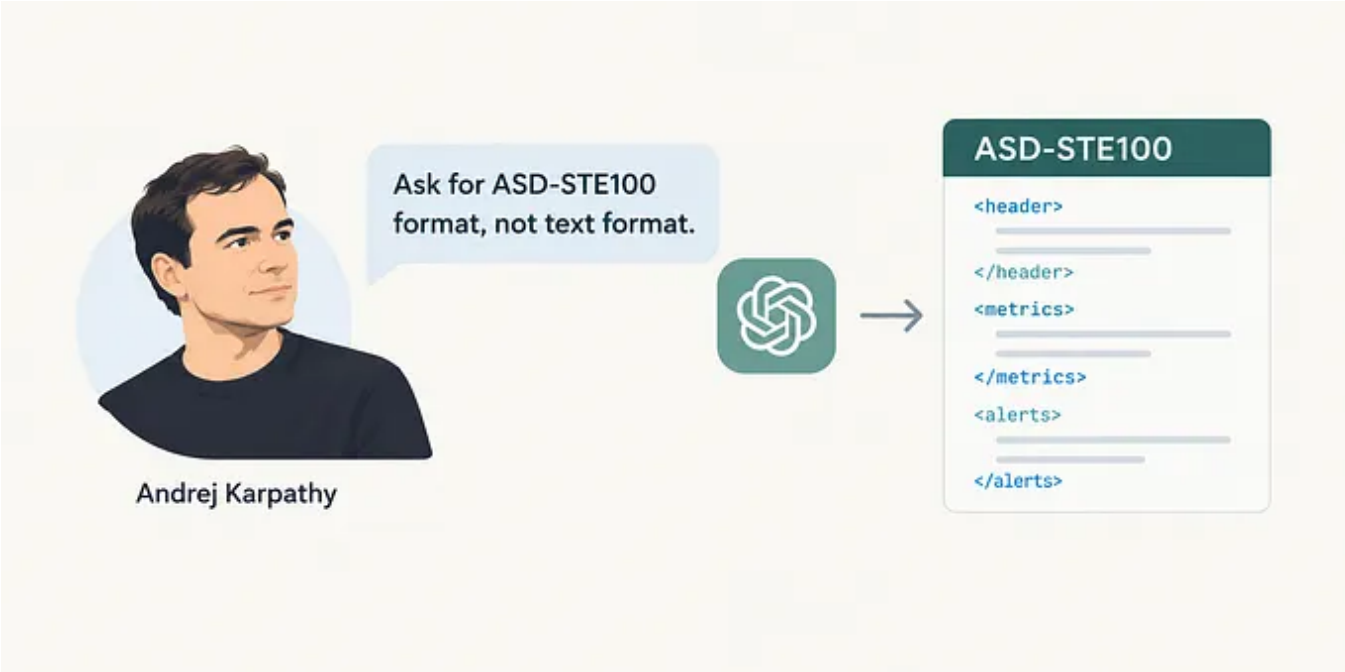


In Generative AI by Jim Clyde Monge · Oct 2

8 New AI Terms You Should Know to Be Ahead of 90% of People

A few more AI terms to know beyond tokens, prompts, and hallucinations.

3.6K 100 32



In Neural Notions by Nikhil · Oct 3

Andrej Karpathy's New suggestion- Ask AI output in ASD-STE100 format and not in Text format

A few days ago, Andrej Karpathy shared a perspective that immediately clicked with how my own daily workflow has been evolving. His premise...

4.7K 99 32





Solo · Jul 26

What Wealthy People Do Before 9 AM That Broke People Do Never

A five-year study tracked 233 millionaires and 128 people struggling financially. The differences weren't income. They weren't lucky. There...

16.9K 579 267



See more recommendations